

# WealthVault

AI-Powered Banking Platform

---

*Punjab & Sind Bank · Hackathon 2026*

Team: Madhur Prakash & Saisha Goel

Generated June 17, 2026

# WealthVault — Punjab & Sind Bank's AI-Powered Banking Platform

*Hackathon Project | Full-Stack Banking & Wealth Management Platform Built for PSB (Punjab & Sind Bank) with production-grade security, AI/ML features, and a compliance simulation lab.*

## Table of Contents

1. Project Overview
2. Feature Set
3. System Architecture
4. Infrastructure & Resources
5. Technology Stack
6. Security Architecture
7. All API Endpoints
8. User Flow Diagrams
9. ML / AI Pipeline
10. Compliance AI (RAG)
11. Sentinel Simulation Lab
12. Deployment Guide
13. Development Timeline (Mar–Jun 2026)
14. Environment Variables
15. Project Structure

## 1. Project Overview

**WealthVault** is a full-stack, production-grade digital banking and wealth management platform developed for the PSB Hackathon. It combines:

- A **customer-facing banking app** (accounts, payments, investments, loans, family banking)
- A **compliance AI assistant** (RAG-based, grounded in RBI & PSB regulations)
- A **security simulation lab** (Sentinel) for training bank employees against phishing, social engineering, and insider threats
- An **ML microservice** connected over gRPC for real-time fraud detection, behavior anomaly detection, cashflow forecasting, and personalized financial advice

The system is designed around **defense-in-depth**: every layer (auth, data, transport, event stream, AI agent) has an independent security control.

It is not a prototype of a single feature. It is a working system where parts interact: payments trigger fraud scoring, chatbot stress signals feed into risk vectors, KYC gates payment access, and admin actions write to an immutable audit log.

## 2. Feature Set

### 2.1 Customer Banking

| Module         | Capabilities                                                                                                                                    |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| Authentication | Multi-step registration (email OTP + phone OTP), login with CAPTCHA, JWT + refresh tokens, httpOnly cookies, Authorization header fallback      |
| Accounts       | Create savings/current accounts, link external bank accounts (Account Aggregator), freeze/unfreeze, delete                                      |
| Transactions   | Credit/debit transactions, spending analysis by category, statement download                                                                    |
| Payments       | UPI & account-to-account transfers, OTP-verified payments, Firebase push approval for large payments (>₹1L), payment history, UPI QR generation |
| Investments    | Mutual funds, stocks, SIPs, investment goals with smart AI insights, portfolio view, live market data, financial news, first-time investor tips |
| Loans          | Apply for loans, track loan status, admin approval/rejection workflow                                                                           |
| Family Banking | Invite family members, set per-member spending limits, family dashboard                                                                         |
| Asset Vault    | Track physical and financial assets, compute total net worth                                                                                    |
| Budget Manager | Create spending budgets per category with real-time alerts                                                                                      |
| Credit Score   | Live credit score computation (300–900) from account age, KYC status, balances, transactions, and loan history — evolves with inertia           |
| Tax Optimizer  | Tax summary derived from income and investment data                                                                                             |
| Risk Dashboard | Composite financial risk score for the user's profile                                                                                           |
| Sessions       | View and revoke all active login sessions per device                                                                                            |
| Notifications  | In-app alerts, fraud alerts, read/unread management, unified notification feed                                                                  |

### 2.2 KYC & Identity Verification

- Aadhaar + PAN card OCR using Tesseract + OpenCV (Gaussian blur + Otsu thresholding)
- Google GenAI-assisted document understanding as primary extraction path
- Verhoeff checksum validation on Aadhaar numbers
- Fuzzy name match between Aadhaar and PAN (≥80% required)
- DOB cross-validation between documents
- Confidence scoring (0–100%) with categorized fraud flags (CRITICAL / ERROR / WARNING)
- Document field masking before any storage

### 2.3 AI Agents

| Agent          | Purpose                                                                                                                                                                 |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Wealth Advisor | Personalized financial advice using real account/transaction/investment data. PII stripped before LLM call. Encrypted request/response via Fernet symmetric encryption. |
| Wealth Teacher | Delivers daily financial literacy lessons tailored to the user's financial profile and investment maturity.                                                             |

Both agents use `anonymize_pii()` to strip name, email, phone, and account number before sending any data to Groq LLM.

## 2.4 Compliance AI

- RAG (Retrieval-Augmented Generation) pipeline grounded in RBI KYC Master Directions and PSB policy documents
- FAISS vector store + BM25 hybrid retriever with RRF score fusion
- Groq LLaMA-3 70B for answer generation (strict "answer only from context" prompt)
- Rule-based compliance checker: Compliant / Risky / Non-Compliant
- Twilio voice call integration: inbound call → speech-to-text → RAG → TTS response
- PII-masked audit log (JSONL) — never logs raw audio
- Rate limiting: 30 text queries/min, 10 voice queries/min
- Multi-language support: English, Hindi, Punjabi

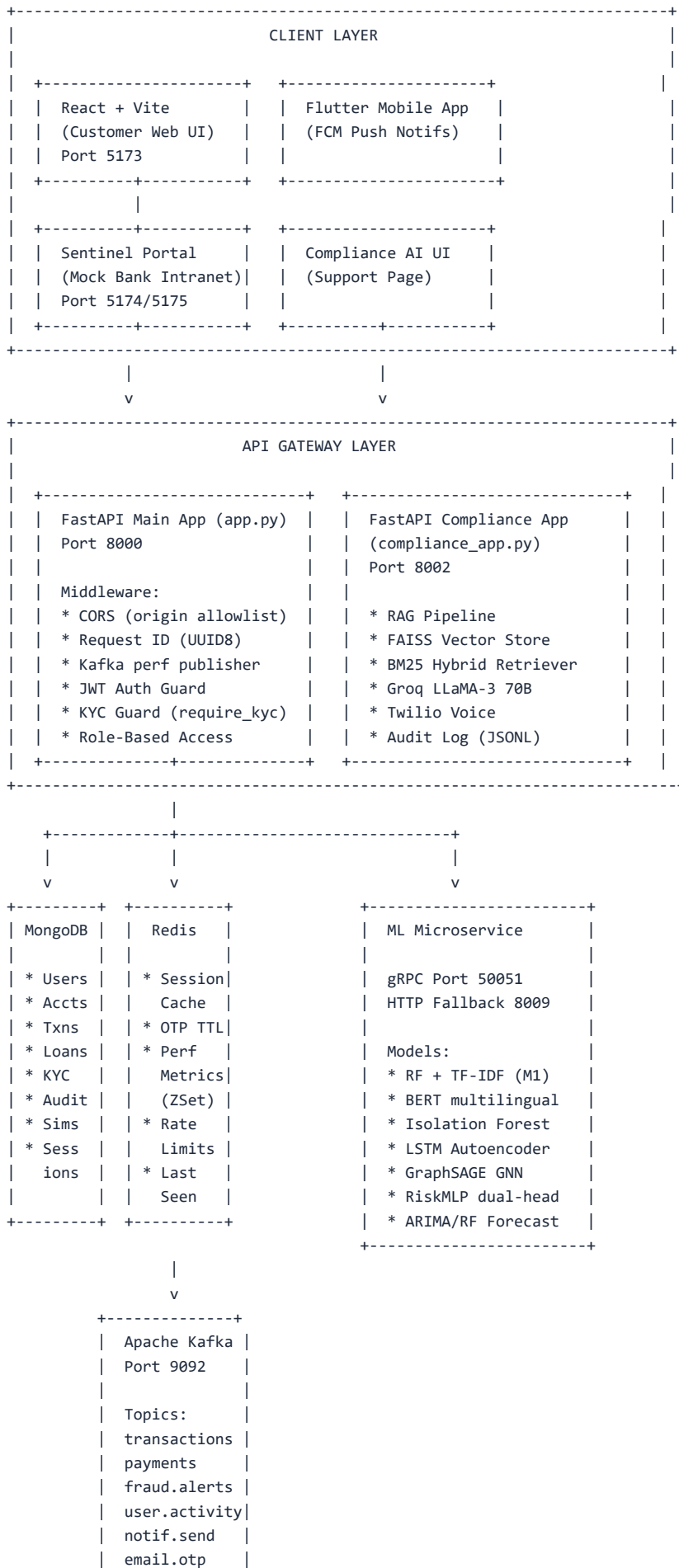
## 2.5 Sentinel Simulation Lab

- Phishing email simulation campaigns targeting bank employees
- Social engineering and incident drill modules
- Employee portal (realistic mock banking intranet) serving as a honeypot
- Credential harvesting detection
- Real-time behavioral tracking (click, hover, scroll, read time, focus)
- Risk scoring and security certification management
- Super-admin dashboard with campaign analytics, leaderboards, and security posture reports
- OSINT scraper integration for employee exposure assessment

## 2.6 Admin Dashboard

- User role management (customer → employee → relationship\_manager → super\_admin)
- KYC approval queue with escalation flow
- Loan approval/rejection
- Fraud alert resolution
- Insider threat scan (GraphSAGE GNN ML model)
- System-wide analytics
- Full audit log trail
- API performance metrics (20-minute sliding window via Redis sorted sets)

## 3. System Architecture



```

|  sim.email  |
|  sys.perf   |
+-----+

```

External Services:

```

+-----+
|  Firebase FCM    -- Push notifications (mobile) |
|  Twilio          -- SMS OTP + voice calls      |
|  Cloudflare      -- Turnstile CAPTCHA          |
|  Groq            -- LLaMA-3 70B LLM inference  |
|  Google GenAI    -- KYC document understanding |
|  Marketstack     -- Live stock market data     |
|  Alpha Vantage   -- Financial data feed        |
|  Finnhub         -- Market news                |
|  NewsAPI         -- Financial news             |
|  Gmail / SMTP    -- Transactional emails       |
+-----+

```

## Why This Architecture?

| Decision                                | Reason                                                                                                                                                                           |
|-----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>FastAPI</b>                          | Async-first, automatic OpenAPI docs, Pydantic v2 validation, highest Python HTTP throughput                                                                                      |
| <b>MongoDB</b>                          | Flexible schema for diverse financial documents (accounts, KYC, simulations have different shapes); TTL indexes for sessions and invitations                                     |
| <b>Redis</b>                            | Sub-millisecond session validation on every request; OTP TTL enforcement; 20-minute performance metrics sliding window via sorted sets                                           |
| <b>Kafka</b>                            | Decouples OTP email delivery, simulation emails, fraud alerts from the request path — no timeout risk; event replay for audit trail                                              |
| <b>Two FastAPI apps</b>                 | Compliance AI is a separate domain with different dependencies (FAISS, Groq, Twilio) and rate limits — isolation prevents a compliance overload from affecting banking endpoints |
| <b>gRPC for ML</b>                      | Strongly typed proto contracts prevent schema drift; binary framing is 3–5× faster than JSON REST for bulk inference; streaming support for future use                           |
| <b>Bearer token interceptor on gRPC</b> | ML server is a separate process/machine — it needs its own auth gate to prevent unauthorized inference calls                                                                     |
| <b>Argon2id for passwords</b>           | OWASP recommended KDF; resistant to GPU brute force (64 MB memory cost, 3 iterations, 2 parallel lanes)                                                                          |
| <b>AES-256-GCM for PII</b>              | Authenticated encryption — tamper detection built in; all sensitive fields (email, phone, account number) encrypted at rest                                                      |
| <b>Deterministic SHA-256 hashes</b>     | Enables unique-index lookups on encrypted fields without decrypting every row (search by hashed_email instead of full scan)                                                      |
| <b>Counting Bloom Filter</b>            | O(1) membership check with false-positive probability < 0.01%; used for fast deduplication of known device fingerprints                                                          |
| <b>Cloudflare Turnstile</b>             | Bot-resistant CAPTCHA on register and login without image puzzle UX friction                                                                                                     |
| <b>Fire-and-forget emails</b>           | Welcome, fraud alert, and transaction emails use <code>asyncio.create_task</code> so they never block the API response                                                           |

## 4. Infrastructure & Resources

### Database Collections (MongoDB)

| Collection                   | Purpose                                                                                                                       |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| users                        | User profiles, hashed PII fields (hashed_email, hashed_phone), KYC status, role, preferences (language, theme, accessibility) |
| accounts                     | Bank accounts with AES-encrypted account numbers, balances, freeze status                                                     |
| transactions                 | All debit/credit records with category, ML risk score, payment channel                                                        |
| payments                     | UPI and account-to-account payment records, OTP state, approval status                                                        |
| loans                        | Loan applications, terms, approval/rejection status                                                                           |
| investments                  | Investment records by type (MF, stock, SIP)                                                                                   |
| investment_goals             | Financial goals with target amounts, deadlines, and progress                                                                  |
| sips                         | SIP schedules and contribution history                                                                                        |
| assets                       | Physical and financial assets for net worth computation                                                                       |
| budgets                      | Budget rules per category with alert thresholds                                                                               |
| families                     | Family group records with head user                                                                                           |
| family_members               | Per-member linking and spending limits (unique index on family_id + user_id)                                                  |
| family_invitations           | Time-limited invite codes (TTL indexed via expires_at)                                                                        |
| fraud_logs                   | Fraud alert records from ML model outputs, indexed on transaction_id and user_id                                              |
| notifications                | In-app notification records, read status (indexed on user_id + read)                                                          |
| kyc_documents                | KYC submission metadata and OCR confidence scores                                                                             |
| known_devices                | Trusted device fingerprints per user (unique index on user_id + fingerprint)                                                  |
| sessions                     | Active JWT sessions (TTL index: auto-delete after 7 days)                                                                     |
| audit_logs                   | Admin action audit trail                                                                                                      |
| portfolios                   | Investment portfolio summary per user (unique index on user_id)                                                               |
| simulation_campaigns         | Sentinel phishing/SE campaign definitions                                                                                     |
| simulation_assignments       | Per-employee simulation task assignments                                                                                      |
| simulation_attempts          | Employee attempt records with pass/fail and behavior events                                                                   |
| simulation_templates         | Email / social engineering / incident drill templates                                                                         |
| employee_simulation_profiles | Per-employee risk scores, flags, certification status                                                                         |

### MongoDB Indexes Created on Startup

```

users.hashd_email      -- unique, partial (string type only)
users.hashd_phone      -- unique, partial (string type only)
accounts.hashd_account_number -- unique, partial (string type only)
accounts.user_id       -- standard index
transactions.account_id -- standard index
transactions.created_at -- standard index
transactions.(user_id, created_at DESC) -- compound index
loans.user_id          -- standard index
fraud_logs.transaction_id -- standard index
fraud_logs.user_id     -- standard index
notifications.(user_id, read) -- compound index
audit_logs.user_id     -- standard index
investments.user_id    -- standard index
portfolios.user_id     -- unique index
kyc_documents.user_id  -- standard index
known_devices.(user_id, fingerprint) -- unique compound index
sessions.created_at    -- TTL index (expires after 604800 seconds = 7 days)
families.head_user_id  -- standard index
family_members.(family_id, user_id) -- unique compound index
family_members.user_id -- standard index
family_invitations.invitation_code -- unique index
family_invitations.(invitee_email, status) -- compound index
family_invitations.expires_at -- TTL index (expires at document time)

```

## Redis Key Patterns

| Key Pattern             | TTL            | Purpose                                                      |
|-------------------------|----------------|--------------------------------------------------------------|
| session:{session_id}    | 7 days         | Active session validation                                    |
| otp:{user_id}           | 5 min          | Login / 2FA OTP                                              |
| reg_otp:{email}         | 5 min          | Registration email OTP                                       |
| reg_phone_otp:{phone}   | 5 min          | Registration phone OTP                                       |
| recovery_otp:{user_id}  | 5 min          | Recovery info OTP                                            |
| reset_otp:{email}       | 5 min          | Password reset OTP                                           |
| last_seen:{user_id}     | 24 h           | User activity tracking                                       |
| cache:{prefix}:{args}   | 5 min          | API response cache                                           |
| system_performance_zset | sliding 20 min | API performance metrics (sorted set, score = Unix timestamp) |
| fcm_token:{user_id}     | —              | Firebase FCM device token                                    |

## Kafka Topics

| Topic                    | Producer           | Consumer(s)                                          |
|--------------------------|--------------------|------------------------------------------------------|
| transactions.created     | transactions route | Fraud detector, notification sender                  |
| payments.initiated       | payments route     | OTP dispatcher, fraud checker                        |
| fraud.alerts             | ML fraud route     | Admin notifier, email service                        |
| user.activity            | auth route         | Redis last_seen updater                              |
| notifications.send       | multiple routes    | In-app notification writer                           |
| email.otpVerification    | auth route         | Email OTP sender<br>(handle_otp_verification)        |
| simulation.email.deliver | sim admin route    | Simulation email deliverer                           |
| system.performance       | request middleware | Redis metrics indexer<br>(handle_performance_metric) |

*All topics fall back to an in-memory queue (capped at 1000 events per topic) when Kafka is unavailable.*

## 5. Technology Stack

### Backend Core

| Technology  | Version | Role                              |
|-------------|---------|-----------------------------------|
| Python      | 3.11    | Runtime                           |
| FastAPI     | ≥0.104  | Async HTTP framework              |
| Uvicorn     | ≥0.24   | ASGI server                       |
| Motor       | ≥3.3    | Async MongoDB driver              |
| Pydantic v2 | ≥2.5    | Schema validation + settings      |
| aioredis    | ≥2.0    | Async Redis client                |
| aiokafka    | ≥0.13   | Async Kafka producer/consumer     |
| grpcio      | ≥1.81   | gRPC transport to ML server       |
| logifyx     | ≥1.1    | Structured colored logging        |
| httpx       | ≥0.25   | Async HTTP client (external APIs) |
| jinja2      | ≥3.1    | Email template rendering          |

### Security Libraries

| Library               | Role                                                        |
|-----------------------|-------------------------------------------------------------|
| python-jose           | JWT HS256 encode/decode                                     |
| argon2-cffi           | Argon2id password hashing (64MB memory, 3 iterations)       |
| cryptography (AESGCM) | AES-256-GCM authenticated encryption for PII fields         |
| cryptography (Fernet) | Symmetric encryption for AI agent request/response payloads |
| mmh3                  | MurmurHash3 for Counting Bloom Filter                       |
| hashlib SHA-256       | Deterministic PII hashing for indexed lookups               |
| Cloudflare Turnstile  | Bot-resistant CAPTCHA (REST verify via httpx)               |

AI / ML Libraries

| Library                  | Role                                                        |
|--------------------------|-------------------------------------------------------------|
| groq                     | LLaMA-3 70B inference (Compliance AI)                       |
| faiss-cpu                | Vector similarity search for RAG retrieval                  |
| sentence-transformers    | all-MiniLM-L6-v2 embeddings for document chunks             |
| rank-bm25                | BM25 sparse retrieval for hybrid search                     |
| pytesseract              | Tesseract OCR for KYC document text extraction              |
| opencv-python-headless   | Image preprocessing (grayscale, blur, threshold) for OCR    |
| thefuzz                  | Fuzzy string matching for Aadhaar-PAN name cross-validation |
| firebase-admin           | Firebase Admin SDK for FCM push notifications               |
| google-api-python-client | Google GenAI for KYC document understanding                 |

External Services

| Service              | Integration Method          | Purpose                                                |
|----------------------|-----------------------------|--------------------------------------------------------|
| Firebase FCM         | firebase-admin SDK          | Push notifications to Flutter mobile app               |
| Twilio               | twilio SDK                  | SMS OTP delivery + compliance voice calls (Twiml)      |
| Cloudflare Turnstile | httpx POST to CF verify API | CAPTCHA on register and login                          |
| Groq                 | groq Python SDK             | LLaMA-3 70B LLM inference for compliance RAG + chatbot |
| Google GenAI         | google-api-python-client    | KYC document OCR and understanding                     |
| Marketstack          | httpx REST                  | Live stock market data                                 |
| Alpha Vantage        | httpx REST                  | Financial data and exchange rates                      |
| Finnhub              | httpx REST                  | Market news feed                                       |
| NewsAPI              | httpx REST                  | Financial news aggregation                             |
| Gmail / SMTP         | aiosmtp + Google OAuth      | Transactional emails (OTP, alerts, welcome)            |
| Deepgram             | httpx (stubbed)             | Speech-to-text (voice compliance queries)              |
| Sarvam AI            | httpx (stubbed)             | Indic language translation for voice                   |

## Supply Chain Security

| Tool      | Purpose                                                                    |
|-----------|----------------------------------------------------------------------------|
| CycloneDX | Software Bill of Materials (SBOM) generated via <code>cyclonedx-bom</code> |
| CycloneDX | Cryptography Bill of Materials (CBOM) tracking all crypto primitives used  |

## Deployment Stack

| Tool           | Role                                                                |
|----------------|---------------------------------------------------------------------|
| Docker         | Container runtime for all services                                  |
| Docker Compose | Multi-service orchestration with health checks and restart policies |
| Kafdrop        | Kafka management and topic inspection UI (port 9000)                |
| Redis Stack    | Redis server + RedisInsight UI (port 8001)                          |

## Frontend Stack

| Technology             | Role                                           |
|------------------------|------------------------------------------------|
| React 18 + Vite        | SPA framework with fast HMR                    |
| TypeScript             | Type safety across components and API layer    |
| Tailwind CSS           | Utility-first styling                          |
| Zustand (with persist) | State management with localStorage persistence |
| React Router v6        | Client-side routing with role-protected routes |
| Shadcn/ui              | Accessible component library                   |
| Recharts               | Financial data charts and graphs               |
| i18next                | Internationalization (EN, HI, PA)              |
| Framer Motion          | Page transitions and 3D animations             |

## 6. Security Architecture

### 6.1 Authentication Flow

User submits email + password + CAPTCHA token



```

| (never decrypt to search| avoids full collection scan
+-----+-----+
| user found
v
+-----+-----+
| AES-256-GCM decrypt    | <- decrypt: email, phone, full_name
| user document fields   |
+-----+-----+
|
v
+-----+-----+
| Argon2id verify        | <- 64 MB memory, 3 iterations, 2 parallel
| (password vs stored hash| OWASP recommended KDF
+-----+-----+
| pass
v
+-----+-----+
| Device fingerprint     | <- hash(IP + User-Agent + Accept-Language)
| check vs known_devices |
+-----+-----+
|
+-----+-----+
New device      Known device
|               |
v               v
* Email alert   Behavior anomaly
* IP geo-lookup ML check:
* Save to       IsolationForest + SVM
known_devices   Anomaly? -> Email alert
|               |
+-----+-----+
|
v
+-----+-----+
| Session creation       | <- UUID session_id
| Redis.setex(session:id,| 7-day TTL
| 7 days, user_id)       |
+-----+-----+
|
v
JWT access token (30 min) + JWT refresh token (7 days)
Both tokens embed session_id claim
Response: tokens in body (mobile) + httpOnly cookies (web)
Kafka: publish "user.activity" event

```

## 6.2 Per-Request Authorization (Every Protected Endpoint)

```

Incoming HTTP request
|
v get_current_user dependency
Check Authorization: Bearer {token} header
| not found? fallback to httpOnly cookie
v
JWT decode (HS256, verify expiry)
Assert: payload["type"] == "access"
|
v
session_id from JWT -> Redis.get("session:{session_id}")
| None? -> 401 "Session has been revoked"
v
MongoDB users.find_one(_id = ObjectId(sub))
| None? -> 401 "User not found"
v

```

```

AES-256-GCM decrypt user document fields
|
v
require_role(*roles) -- 403 if role not in allowed set
|
v
require_kyc -- 403 if kyc_status != "verified" (payment-sensitive routes)
|
v
Endpoint handler executes

```

## 6.3 Data Security Layers

FIELD-LEVEL ENCRYPTION (AES-256-GCM, 256-bit key, 96-bit nonce):

Encrypted before MongoDB write:

```

users    -> email, phone, full_name
accounts -> account_number, account_holder_name
Nonce prepended to ciphertext, base64-encoded for storage

```

SEARCHABLE DETERMINISTIC HASH (SHA-256, normalized lowercase):

```

users.hash_email      -> unique sparse MongoDB index
users.hash_phone      -> unique sparse MongoDB index
accounts.hash_account_number -> unique sparse MongoDB index
Purpose: lookup by sensitive field without decrypting every document

```

AI AGENT PAYLOAD ENCRYPTION (Fernet symmetric):

```

/agents/advisor and /agents/teacher:
  Client sends: { encrypted_token: "<fernet(request_json)>" }
  Server returns: { encrypted_token: "<fernet(response_json)>" }
Prevents clear-text financial data in transit even over HTTPS

```

PII STRIPPING BEFORE LLM (anonymize\_pii):

```

Masks: name->"****", email->"***@***.com", phone->"XXXX-XXXX",
        account_number->"XXX{last4}"
Applied before every Groq API call in chatbot, advisor, teacher

```

AUDIT LOG MASKING (mask\_pii):

```

Applied to all query text in compliance audit JSONL
Never logs: raw audio, full account numbers, passwords

```

HOMOMORPHIC ENCRYPTION SIMULATION (chatbot):

```

Financial amounts encoded as HE_CT_{val} before LLM context
LLM response decoded back to ₹{amount} before user response

```

## 6.4 Payment Security Chain

POST /payments/initiate

```

|
v require_kyc -> 403 if not KYC-verified
v validate source account belongs to user
v validate balance ≥ amount
v generate 6-digit OTP -> Redis (5-min TTL)
|
+-- SMS via Twilio
+-- Email via Gmail
|
| amount > ₹1,00,000 (LARGE_PAYMENT_THRESHOLD)?
|   | Yes
|   v
|   Firebase FCM push to Flutter app
|   (title: "Large Payment Approval Required")

```

```
| User taps YES/NO -> POST /payments/{id}/respond
|
v POST /payments/verify (OTP from Redis)
v Debit source account, credit destination
v Create transaction records
v Kafka: "payments.initiated" event
v ML fraud check (async, non-blocking)
v Email + in-app notification (fire-and-forget)
```

## 6.5 Complete Security Controls Summary

| Control                  | Implementation                                      | Layer        |
|--------------------------|-----------------------------------------------------|--------------|
| Password hashing         | Argon2id — 64 MB, 3 iter, 2 parallel                | Auth         |
| Access tokens            | JWT HS256, 30-min expiry, session_id claim          | Auth         |
| Refresh tokens           | JWT HS256, 7-day expiry, Redis-backed session       | Auth         |
| Session revocation       | Redis DELETE on logout; TTL auto-expiry             | Auth         |
| CAPTCHA                  | Cloudflare Turnstile (register + login)             | Auth         |
| PII field encryption     | AES-256-GCM per field, random 96-bit nonce          | Data at rest |
| Searchable PII           | SHA-256 deterministic hash + sparse unique index    | Data         |
| Agent payload encryption | Fernet symmetric (request + response)               | Agent        |
| LLM PII stripping        | anonymize_pii() before every Groq call              | Agent        |
| CORS                     | Explicit per-origin allowlist (no wildcard in prod) | Transport    |
| Device fingerprinting    | SHA-256(IP + UA) → MongoDB known_devices            | Session      |
| New device alert         | Email notification + IP geolocation lookup          | Session      |
| Session tracking         | All active sessions visible and revocable           | Session      |
| Behavior anomaly ML      | Isolation Forest + per-user SVM                     | ML           |
| Sequence anomaly ML      | LSTM Autoencoder on transaction history             | ML           |
| Insider threat ML        | GraphSAGE GNN on user-merchant graph                | ML           |
| Large payment approval   | Firebase FCM push + OTP dual-factor                 | Payment      |
| Payment OTP              | 6-digit, 5-min TTL in Redis                         | Payment      |
| KYC verification         | OCR + Verhoeff checksum + fuzzy name match          | Identity     |
| Aadhaar masking          | Only last 4 digits stored (XXXX-XXXX-{last4})       | Identity     |
| Compliance audit log     | JSONL with PII masking, latency, rule triggers      | Compliance   |
| Rate limiting            | 30/min text, 10/min voice (Compliance AI)           | Compliance   |
| SBOM / CBOM              | CycloneDX BOM for supply chain transparency         | Supply Chain |
| gRPC auth                | Bearer token interceptor on every ML channel call   | ML transport |
| Counting Bloom Filter    | O(1) device deduplication, error rate < 0.01%       | Performance  |

## 7. All API Endpoints

Base prefix: /api/v1 for all banking endpoints. Compliance routes: /api/v1/compliance. Simulation tracking: /api/track.

## 7.1 Authentication (/auth)

| Method | Path                                  | Auth          | Description                                                   |
|--------|---------------------------------------|---------------|---------------------------------------------------------------|
| POST   | /auth/register                        | Public        | Initiate registration (validate + send email OTP)             |
| POST   | /auth/register/send-email-otp         | Public        | Resend registration email OTP                                 |
| POST   | /auth/register/verify-email-otp       | Public        | Verify registration email OTP                                 |
| POST   | /auth/register/send-phone-otp         | Public        | Send phone OTP during registration                            |
| POST   | /auth/register/complete               | Public        | Complete registration (verify both OTPs, create user)         |
| POST   | /auth/send-phone-otp                  | Public        | Send phone OTP for SIM binding                                |
| POST   | /auth/verify-phone                    | Public        | Verify phone OTP for SIM binding                              |
| POST   | /auth/login                           | Public        | Login with CAPTCHA, Argon2, device check                      |
| POST   | /auth/admin/login                     | Public        | Admin-specific login flow                                     |
| POST   | /auth/logout                          | JWT           | Clear auth cookies, return success                            |
| POST   | /auth/refresh                         | Cookie/Header | Issue new access token from refresh token                     |
| GET    | /auth/me                              | JWT           | Get current authenticated user profile                        |
| PUT    | /auth/profile                         | JWT           | Update profile (name, avatar, language, theme, accessibility) |
| POST   | /auth/send-otp                        | JWT           | Generate OTP for logged-in user operations                    |
| POST   | /auth/verify-otp                      | JWT           | Verify OTP                                                    |
| PUT    | /auth/recovery-info                   | JWT           | Update recovery email / phone                                 |
| POST   | /auth/recovery-info/send-otp          | JWT           | Send OTP to recovery contact                                  |
| POST   | /auth/recovery-info/verify-and-update | JWT           | Verify OTP and save new recovery info                         |
| POST   | /auth/request-password-reset          | Public        | Send password reset OTP to email                              |
| POST   | /auth/reset-password                  | Public        | Reset password using OTP                                      |
| POST   | /auth/security/report                 | JWT           | Report "this wasn't me" → logout + flag                       |

## 7.2 Sessions (/sessions)

| Method | Path                   | Auth | Description                                    |
|--------|------------------------|------|------------------------------------------------|
| GET    | /sessions              | JWT  | List all active sessions for current user      |
| DELETE | /sessions/{session_id} | JWT  | Revoke a specific session (logout that device) |
| DELETE | /sessions              | JWT  | Revoke all sessions (logout all devices)       |

### 7.3 Accounts (/accounts)

| Method | Path                            | Auth | Description                                       |
|--------|---------------------------------|------|---------------------------------------------------|
| POST   | /accounts                       | JWT  | Create a new bank account                         |
| GET    | /accounts                       | JWT  | List all user accounts                            |
| GET    | /accounts/{account_id}          | JWT  | Get specific account details                      |
| POST   | /accounts/link-external         | JWT  | Link external bank account via Account Aggregator |
| PUT    | /accounts/{account_id}/freeze   | JWT  | Freeze account (blocks transactions)              |
| PUT    | /accounts/{account_id}/unfreeze | JWT  | Unfreeze account                                  |
| DELETE | /accounts/{account_id}          | JWT  | Delete account                                    |

### 7.4 Transactions (/transactions)

| Method | Path                            | Auth    | Description                               |
|--------|---------------------------------|---------|-------------------------------------------|
| POST   | /transactions                   | JWT+KYC | Create a debit/credit transaction         |
| GET    | /transactions                   | JWT     | List transactions with pagination/filters |
| GET    | /transactions/spending-analysis | JWT     | Categorical spending breakdown            |
| GET    | /transactions/{transaction_id}  | JWT     | Get specific transaction                  |

### 7.5 Payments (/payments)

| Method | Path                           | Auth    | Description                                       |
|--------|--------------------------------|---------|---------------------------------------------------|
| POST   | /payments/initiate             | JWT+KYC | Initiate UPI or account payment (triggers OTP)    |
| POST   | /payments/verify               | JWT+KYC | Verify OTP and execute payment                    |
| POST   | /payments/{payment_id}/respond | JWT+KYC | Approve/reject via Firebase push (large payments) |
| POST   | /payments/{payment_id}/resend  | JWT     | Resend OTP (choose email or SMS channel)          |
| GET    | /payments                      | JWT     | List payment history                              |
| GET    | /payments/{payment_id}         | JWT     | Get specific payment details                      |
| GET    | /payments/qr/generate          | JWT     | Generate UPI QR code data                         |

## 7.6 Investments (/investments)

| Method | Path                              | Auth | Description                                    |
|--------|-----------------------------------|------|------------------------------------------------|
| POST   | /investments                      | JWT  | Record a new investment                        |
| GET    | /investments                      | JWT  | List all investments                           |
| GET    | /investments/portfolio            | JWT  | Full portfolio summary with performance data   |
| GET    | /investments/stocks               | JWT  | Live stock data (Marketstack API)              |
| GET    | /investments/news                 | JWT  | Financial news (Finnhub + NewsAPI)             |
| GET    | /investments/goals/smart-insights | JWT  | AI-generated investment goal insights          |
| POST   | /investments/goals                | JWT  | Create an investment goal                      |
| GET    | /investments/goals                | JWT  | List all investment goals                      |
| DELETE | /investments/goals/{goal_id}      | JWT  | Delete an investment goal                      |
| POST   | /investments/sips                 | JWT  | Create a SIP (Systematic Investment Plan)      |
| GET    | /investments/sips                 | JWT  | List all SIPs                                  |
| PATCH  | /investments/sips/{sip_id}        | JWT  | Update SIP (pause, modify amount)              |
| GET    | /investments/first-time-tips      | JWT  | Financial tips for first-time investors        |
| POST   | /investments/mark-invested        | JWT  | Mark user as experienced investor (hides tips) |

## 7.7 Loans (/loans)

| Method | Path             | Auth    | Description                   |
|--------|------------------|---------|-------------------------------|
| POST   | /loans/apply     | JWT+KYC | Apply for a loan              |
| GET    | /loans           | JWT     | List user's loan applications |
| GET    | /loans/{loan_id} | JWT     | Get specific loan details     |

## 7.8 ML / AI Inference (/ml)

Routes gRPC ML server when USING\_GRPC=true, otherwise HTTP fallback

| Method | Path                     | Auth | Description                                             |
|--------|--------------------------|------|---------------------------------------------------------|
| GET    | /ml/recommendations      | JWT  | Personalized financial product recommendations          |
| POST   | /ml/fraud-check          | JWT  | Real-time transaction fraud check (Random Forest)       |
| POST   | /ml/behavior-anomaly     | JWT  | Behavioral anomaly detection (Isolation Forest + SVM)   |
| POST   | /ml/forecast-cashflow    | JWT  | Cashflow forecast for account (ARIMA/RF, N-day horizon) |
| GET    | /ml/spending-insights    | JWT  | ML-generated spending pattern analysis                  |
| GET    | /ml/account-insights     | JWT  | Account health insights                                 |
| GET    | /ml/sip-insights         | JWT  | SIP performance and optimization insights               |
| GET    | /ml/asset-insights       | JWT  | Asset composition and rebalancing insights              |
| GET    | /ml/loan-insights        | JWT  | Loan risk and repayment insights                        |
| POST   | /ml/whatif-scenario      | JWT  | What-if financial scenario simulation                   |
| POST   | /ml/chatbot              | JWT  | AI financial chatbot (stress detection + Groq LLaMA-3)  |
| POST   | /ml/classify-transaction | JWT  | BERT multilingual transaction classifier                |
| POST   | /ml/voice-agent          | JWT  | Voice-based financial assistant                         |

## 7.9 KYC (/kyc)

| Method | Path        | Auth | Description                                      |
|--------|-------------|------|--------------------------------------------------|
| POST   | /kyc/upload | JWT  | Upload Aadhaar front/back + PAN for verification |
| GET    | /kyc/status | JWT  | Check KYC verification status                    |

## 7.10 Notifications (/notifications)

| Method | Path                                  | Auth | Description                                    |
|--------|---------------------------------------|------|------------------------------------------------|
| POST   | /notifications/fcm-token              | JWT  | Register Firebase FCM device token             |
| GET    | /notifications                        | JWT  | List all notifications                         |
| PUT    | /notifications/{notification_id}/read | JWT  | Mark single notification as read               |
| PUT    | /notifications/read-all               | JWT  | Mark all notifications as read                 |
| GET    | /notifications/unread-count           | JWT  | Get unread notification count                  |
| GET    | /notifications/alerts                 | JWT  | List fraud and security alerts                 |
| PUT    | /notifications/alerts/{alert_id}/read | JWT  | Mark alert as read                             |
| GET    | /notifications/alerts/unread-count    | JWT  | Count unread alerts                            |
| GET    | /notifications/unified                | JWT  | Unified feed (notifications + alerts combined) |

### 7.11 Account Aggregator (/aa)

| Method | Path                          | Auth | Description                                     |
|--------|-------------------------------|------|-------------------------------------------------|
| POST   | /aa/consent/request           | JWT  | Initiate consent for external bank data sharing |
| GET    | /aa/consent/{consent_id}      | JWT  | Check consent status                            |
| GET    | /aa/accounts                  | JWT  | Fetch linked external bank accounts             |
| GET    | /aa/transactions/{account_id} | JWT  | Fetch transactions from external account        |

### 7.12 Family Banking (/family)

| Method | Path                            | Auth | Description                              |
|--------|---------------------------------|------|------------------------------------------|
| POST   | /family/invite                  | JWT  | Invite a family member via email         |
| POST   | /family/respond                 | JWT  | Accept or reject a family invitation     |
| POST   | /family/set-limit               | JWT  | Set spending limit for a family member   |
| GET    | /family/my-family               | JWT  | Get family group details and all members |
| GET    | /family/invitations             | JWT  | List pending invitations                 |
| DELETE | /family/member/{member_user_id} | JWT  | Remove a family member                   |

### 7.13 Assets (/assets)

| Method | Path                      | Auth | Description                             |
|--------|---------------------------|------|-----------------------------------------|
| POST   | /assets                   | JWT  | Add a new asset (physical or financial) |
| GET    | /assets                   | JWT  | List all assets                         |
| DELETE | /assets/{asset_id}        | JWT  | Delete an asset                         |
| GET    | /assets/net-worth-summary | JWT  | Compute total net worth from all assets |

### 7.14 Budgets (/budgets)

| Method | Path                 | Auth | Description                             |
|--------|----------------------|------|-----------------------------------------|
| POST   | /budgets             | JWT  | Create a category budget with threshold |
| GET    | /budgets             | JWT  | List all budgets                        |
| DELETE | /budgets/{budget_id} | JWT  | Delete a budget                         |

### 7.15 Credit, Tax, Risk

| Method | Path          | Auth | Description                                      |
|--------|---------------|------|--------------------------------------------------|
| GET    | /credit/score | JWT  | Compute live credit score (300–900 with inertia) |
| GET    | /tax/summary  | JWT  | Tax optimization summary                         |
| GET    | /risk/summary | JWT  | Composite financial risk score                   |

### 7.16 AI Agents (/agents)

| Method | Path            | Auth | Description                                  |
|--------|-----------------|------|----------------------------------------------|
| POST   | /agents/advisor | JWT  | Fernet-encrypted Wealth Advisor response     |
| POST   | /agents/teacher | JWT  | Fernet-encrypted Wealth Teacher daily lesson |

### 7.17 Compliance AI (/compliance)

| Method | Path                      | Auth           | Description                             |
|--------|---------------------------|----------------|-----------------------------------------|
| POST   | /compliance/query         | Public         | Text-based compliance query via RAG     |
| POST   | /compliance/call/inbound  | Twilio webhook | Twiml for inbound compliance phone call |
| POST   | /compliance/call/process  | Twilio webhook | Process voice recording → RAG → TTS     |
| POST   | /compliance/call/continue | Twilio webhook | Continue or end the compliance call     |

## 7.18 Admin (/admin)

| Method | Path                                          | Auth (Role) | Description                                     |
|--------|-----------------------------------------------|-------------|-------------------------------------------------|
| GET    | /admin/users                                  | Admin       | List all users                                  |
| PUT    | /admin/users/{user_id}/role                   | Admin       | Change user role                                |
| PUT    | /admin/users/{user_id}/deactivate             | Admin       | Deactivate user account                         |
| PUT    | /admin/users/{user_id}/activate               | Admin       | Reactivate user account                         |
| GET    | /admin/kyc/pending                            | Admin       | List pending KYC submissions                    |
| GET    | /admin/kyc/escalated                          | Admin       | List escalated KYC cases                        |
| PUT    | /admin/kyc/{user_id}/action                   | Admin       | Approve / reject / escalate KYC                 |
| GET    | /admin/loans                                  | Admin       | List all loan applications                      |
| PUT    | /admin/loans/{loan_id}/approve                | Admin       | Approve loan                                    |
| PUT    | /admin/loans/{loan_id}/reject                 | Admin       | Reject loan                                     |
| GET    | /admin/fraud-alerts                           | Admin       | List all fraud alerts                           |
| PUT    | /admin/fraud-alerts/{alert_id}/resolve        | Admin       | Resolve a fraud alert                           |
| GET    | /admin/insider-threat-check                   | Admin       | Run GraphSAGE insider threat scan               |
| GET    | /admin/analytics                              | Admin       | System-wide analytics dashboard                 |
| GET    | /admin/audit-logs                             | Admin       | View full audit log trail                       |
| GET    | /admin/performance                            | Admin       | API performance metrics (20-min sliding window) |
| GET    | /employee-notifications/notifications/summary | Employee    | Employee notification summary                   |

## 7.19 Sentinel Simulation Lab

| Method | Path                                    | Auth       | Description                                    |
|--------|-----------------------------------------|------------|------------------------------------------------|
| GET    | /admin/sim/stats/overview               | SuperAdmin | Campaign stats overview                        |
| GET    | /admin/sim/employees                    | SuperAdmin | Paginated employee simulation profiles         |
| GET    | /admin/sim/employees/{hash}             | SuperAdmin | Individual employee profile                    |
| POST   | /admin/sim/campaigns/single             | SuperAdmin | Trigger single-target campaign                 |
| POST   | /admin/sim/campaigns/random             | SuperAdmin | Trigger random-target campaign                 |
| POST   | /admin/sim/campaigns/bulk               | SuperAdmin | Trigger bulk campaign for department           |
| GET    | /admin/sim/campaigns                    | SuperAdmin | List all campaigns                             |
| GET    | /admin/sim/campaigns/{id}               | SuperAdmin | Campaign details                               |
| POST   | /admin/sim/campaigns/{id}/cancel        | SuperAdmin | Cancel active campaign                         |
| GET    | /admin/sim/threats                      | SuperAdmin | List detected insider threats                  |
| POST   | /admin/sim/threats/{id}/approve         | SuperAdmin | Approve threat escalation                      |
| POST   | /admin/sim/threats/{id}/reject          | SuperAdmin | Reject threat                                  |
| POST   | /admin/sim/scraper/run                  | SuperAdmin | Run OSINT scraper for employee exposure        |
| GET    | /admin/sim/reports/leaderboard          | SuperAdmin | Security awareness leaderboard                 |
| GET    | /admin/sim/reports/flagged              | SuperAdmin | High-risk flagged employees                    |
| GET    | /admin/sim/reports/posture              | SuperAdmin | Org-wide security posture                      |
| POST   | /portal/login                           | Employee   | Mock portal login                              |
| GET    | /portal/dashboard                       | Employee   | Portal dashboard                               |
| GET    | /portal/inbox                           | Employee   | Simulated email inbox (real + fake + phishing) |
| GET    | /portal/inbox/{email_id}                | Employee   | Read specific email                            |
| POST   | /portal/inbox/{email_id}/report         | Employee   | Report suspicious email                        |
| GET    | /portal/phishing/portal-session/{token} | Public     | Phishing session landing page (honeypot)       |
| GET    | /portal/phishing/click/{token}          | Public     | Track phishing link click event                |
| POST   | /portal/phishing/credentials/{token}    | Public     | Track credential submission                    |
| GET    | /portal/social/{token}                  | Public     | Social engineering landing page                |
| POST   | /portal/social/respond/{token}          | Public     | Track social engineering response              |

| Method | Path                             | Auth   | Description                                                    |
|--------|----------------------------------|--------|----------------------------------------------------------------|
| GET    | /portal/incident/form/{token}    | Public | Incident drill form                                            |
| POST   | /portal/incident/submit/{token}  | Public | Submit incident drill response                                 |
| POST   | /api/track/behavior/{attempt_id} | Public | Real-time behavior telemetry (click, hover, scroll, read_time) |

## 8. User Flow Diagrams

### 8.1 New Customer Registration

```

User opens /register
  |
  v POST /auth/register
+-----+
| 1. Validate: name, email, password, phone |
| (phone: Indian format, starts 6-9, 10 dig)|
| 2. Cloudflare Turnstile CAPTCHA verify    |
| 3. SHA-256(email) check -- already exists? |
+-----+
      | OK
      v POST /auth/register/send-email-otp
+-----+
| 6-digit OTP generated -> Redis 5 min TTL    |
| OTP sent via Gmail API                     |
+-----+
      |
      v POST /auth/register/verify-email-otp
Email OTP verified
      |
      v POST /auth/register/send-phone-otp
+-----+
| SMS OTP via Twilio -> Redis 5 min TTL      |
+-----+
      |
      v POST /auth/register/complete
+-----+
| Both OTPs verified                        |
| * Argon2id hash password                  |
| * AES-256-GCM encrypt: email, phone, name |
| * SHA-256 hash: email, phone (for indexes) |
| * Insert MongoDB user document            |
| * Bloom filter updated                    |
| * Welcome email sent (fire-and-forget)     |
+-----+
      |
      v Redirect to KYC
+-----+
| POST /kyc/upload                          |
| * Aadhaar front + back (base64)           |
| * PAN card (base64)                       |
|
| Processing:                               |
| * Gaussian blur + Otsu threshold (OpenCV) |
| * Tesseract OCR / Google GenAI extraction |
| * Verhoeff checksum on Aadhaar            |
+-----+

```

```

| * Fuzzy name match Aadhaar ↔ PAN (≥80%) |
| * DOB cross-validation |
| * Confidence score computed (0-100%) |
| * Status -> "pending" |
+-----+
| Admin reviews queue
v PUT /admin/kyc/{user_id}/action
KYC Approved -> status = "verified"
Full access unlocked (payments, loans)

```

## 8.2 Login and Session Lifecycle

User enters email + password + CAPTCHA

```

|
v POST /auth/login
+-----+
| Turnstile verify -> CF API |
| SHA-256(email) -> MongoDB lookup |
| AES-256-GCM decrypt user doc |
| Argon2id.verify(password) |
+-----+
|
+-----+
New device      Known device
|               |
v               v
* Email alert    Isolation Forest
* IP geo lookup  + SVM anomaly check
* Store fingerprint Anomaly? -> Email alert
|               |
+-----+
|
v
Redis: session:{UUID} -> user_id [7-day TTL]
JWT access token (30 min, has session_id)
JWT refresh token (7 days, has session_id)
Set httpOnly cookies + return in body

Kafka -> "user.activity" event -> Redis last_seen update
|
| Every request (protected route):
v
JWT decode -> session_id -> Redis.get(session:id)
None? -> 401 "Session revoked"
|
v
GET /sessions -> user sees all active devices
DELETE /sessions/{id} -> revoke one device
DELETE /sessions -> revoke all (logout everywhere)

```

## 8.3 Payment End-to-End Flow

User sends ₹X to VPA or account number

```

|
v POST /payments/initiate
+-----+
| require_kyc -> must be KYC-verified |
| Source account belongs to user? |
| Balance ≥ amount? |
| Mode: UPI (VPA) or Account transfer |
+-----+

```

```

|
v Generate 6-digit OTP -> Redis 5 min
+-----+
| Send SMS (Twilio) |
| Send Email (Gmail) |
+-----+
|
amount > ₹1,00,000?
| Yes
v
Firebase FCM push to Flutter
"Large Payment Approval Required"
User taps YES -> POST /payments/{id}/respond

|
v POST /payments/verify
+-----+
| OTP verified from Redis |
| Debit source account (MongoDB update) |
| Credit destination account |
| Create debit + credit transaction docs |
| Update payment status -> "completed" |
+-----+
|
v Parallel async:
* Kafka: "payments.initiated" -> fraud ML check
* Email: transaction alert (fire-and-forget)
* In-app notification created
* ML fraud score stored in fraud_logs

```

## 8.4 Compliance AI Voice Call Flow

```

Employee calls PSB compliance hotline (Twilio number)
|
v Twilio -> POST /compliance/call/inbound
+-----+
| TwiML: "Welcome to PSB compliance. |
| Ask your question after the beep." |
| Record: max 30s, action=/call/process |
+-----+
| Employee speaks
v POST /compliance/call/process
+-----+
| Download recording -> Deepgram STT |
| Detect language (EN/HI/PA) |
| Confidence < 0.65? -> ask to repeat |
+-----+
|
v Hybrid RAG retrieval
+-----+
| FAISS (MiniLM-L6-v2) + BM25 -> top-5 |
| RRF score fusion |
| Rule-based compliance check |
| Groq LLaMA-3 70B generation |
+-----+
|
v Sarvam translate (if non-English)
+-----+
| TwiML: speak answer (Polly.Aditi) |
| "Would you like another question?" |
| Gather keypress -> /call/continue |
+-----+
|

```

```

+-----+-----+
| Press 1: redirect      | Press other: hangup
| -> /call/inbound again |
+-----+-----+
|
|
Audit JSONL: query_masked, answer_preview,
             compliance_status, triggered_rules,
             latency_ms, language

```

## 8.5 Sentinel Simulation Flow

```

SuperAdmin selects employee + module type
|
v POST /admin/sim/campaigns/single
+-----+-----+
| Pick template (phishing/SE/drill) |
| Create simulation_assignment in DB  |
| Kafka: "simulation.email.deliver"  |
+-----+-----+
| Event consumer delivers
|
v
Spoofed email arrives in employee's inbox
(visible in /portal/inbox AND real email)
|
+-----+-----+
|                               |
Employee clicks                 Employee reports
phishing link                   -> POST /portal/inbox/{id}/report
|                               |
v                               v
GET /portal/phishing/click/{token} attempt.passed = true
Real-time: POST /api/track/behavior Score improved
|
v
Phishing landing page
(fake PSB credentials page)
|
v POST /portal/phishing/credentials/{token}
Credential harvested -> attempt.passed = false
Risk score increased
Flagged in employee profile

SuperAdmin views:
* /admin/sim/stats/overview    -- real-time stats
* /admin/sim/reports/flagged   -- high-risk employees
* /admin/sim/reports/leaderboard -- security rankings
* /admin/sim/reports/posture   -- org-wide posture

```

## 9. ML / AI Pipeline

The ML microservice runs separately and exposes a gRPC server. WealthVault connects via `MLClient` in `app/services/grpc_client.py`. Bearer token auth is injected on every call via `_BearerTokenInterceptor`.

### ML Models

| Model ID        | Type                            | Task                                                          | gRPC Method                     |
|-----------------|---------------------------------|---------------------------------------------------------------|---------------------------------|
| M1              | Random Forest + TF-IDF          | Transaction category classification by merchant + channel     | PredictTransactionCategory      |
| M2              | BERT multilingual               | Free-text transaction classification with confidence          | ClassifyTransactionMultilingual |
| M3              | BERT fine-tuned                 | Coercion / stress detection in chat messages                  | DetectChatStress                |
| Cashflow        | ARIMA / Random Forest           | Predict daily net cashflow for N days                         | ForecastCashflow                |
| BehaviorAnomaly | Isolation Forest + per-user SVM | Detect unusual login/behavior patterns                        | DetectBehaviorAnomaly           |
| M4 (RiskMLP)    | Dual-head MLP                   | Financial risk score from feature vector                      | CalculateRiskScore              |
| SeqAnomaly      | LSTM Autoencoder                | Detect anomalous transaction sequences (reconstruction error) | DetectSequenceAnomaly           |
| InsiderThreat   | GraphSAGE GNN                   | Graph-based insider threat detection on user-merchant edges   | DetectInsiderThreat             |

### gRPC Proto (`ml.proto`)

Defines 8 RPC methods. Generated stubs in `app/shared/proto/ml_pb2.py` and `ml_pb2_grpc.py`. The `MLClient` class wraps each stub call with type-safe Python methods.

### HTTP Fallback

If `USING_GRPC=false`, `ml_http.py` routes all ML calls to the ML server's REST API at `ML_HTTP_HOST` using `Authorization: Bearer {ML_API_TOKEN}`.

### Homomorphic Encryption Simulation (Chatbot)

Financial amounts are encoded as `HE_CT_{int(value*8191)}` tokens before being included in the LLM context window. The LLM receives and returns opaque tokens. `decode_llm_response()` decrypts them back to `₹{amount}` format before returning to the user — simulating homomorphic encryption for secure LLM context passing.

## 10. Compliance AI (RAG)

The compliance AI runs as a **separate FastAPI service** on port 8002 to isolate its heavy ML dependencies (FAISS, sentence-transformers) and different rate limits from the main banking API.

### RAG Pipeline

Documents ingested at startup (`ingestion.py`):

- RBI KYC Master Directions (PDF)
- PSB internal policy documents

```
|
  v pdfplumber + pypdf -> text chunks
CHUNK_SIZE=700 tokens, CHUNK_OVERLAP=100 tokens
|
  v all-MiniLM-L6-v2 embeddings
FAISS index + BM25 index -> saved to ./data/faiss_index

Query time (rag_pipeline.py):
  User query
  |
  v HybridRetriever
FAISS: cosine similarity search -> top-K=5 semantic chunks
BM25: BM25Okapi keyword search -> top-K=5 lexical chunks
RRF: Reciprocal Rank Fusion -> deduplicated final context
  |
  v Groq LLaMA-3 70B (llama3-70b-8192)
System: "Answer ONLY from context. Cite source. No hallucination."
User: REGULATORY CONTEXT: {chunks}\n\nUSER QUERY: {query}
  |
  v compliance_checker.py
Pattern-match compliance rules on query text
Output: Compliant / Risky / Non-Compliant + triggered_rules[]
  |
  v audit_logger.py
JSONL: query_masked, answer_preview, compliance_status,
       triggered_rules, confidence, latency_ms
```

Compliance Rules Implemented

- KYC periodic update: 2 years (high risk), 8 years (medium risk), 10 years (low risk) — RBI KYC Master Directions Para 38
- Generic KYC interval checks
- AML customer due diligence thresholds
- CTR (Cash Transaction Report) requirements
- STR (Suspicious Transaction Report) triggers
- PMLA obligations

11. Sentinel Simulation Lab

Sentinel is a built-in security awareness training system for PSB employees. It creates realistic phishing and social engineering simulations within the platform itself.

Simulation Modules

| Module             | Attack Type        | How It Works                                                           |
|--------------------|--------------------|------------------------------------------------------------------------|
| Phishing           | Email phishing     | Spoofed internal PSB email with malicious link to fake credential page |
| Social Engineering | Pretexting         | Fake urgent authority email requiring information disclosure           |
| Incident Drill     | Awareness training | Fake security incident requiring employee response                     |

## Scoring Algorithm

Each attempt is scored based on:

- Did the employee click the link? (negative)
- Did the employee submit credentials? (critical negative)
- Did the employee report the email? (positive)
- Time-to-report (faster = better)
- Read time vs. click rate ratio

Scores accumulate into an `employee_simulation_profile` with certification status, risk tier, and flag status.

## 12. Deployment Guide

### Prerequisites

| Component      | Requirement                                    |
|----------------|------------------------------------------------|
| Docker         | 20.x+                                          |
| Docker Compose | 2.x+                                           |
| MongoDB        | Atlas URI or local 7.x                         |
| ML Server      | Running separately with gRPC on port 50051     |
| Firebase       | Project with FCM enabled, service account JSON |

### Service Map

| Service                | Image                              | Port        | Health Check |
|------------------------|------------------------------------|-------------|--------------|
| backend_app            | Custom (Dockerfile.app)            | 8000        | GET /docs    |
| backend_compliance_app | Custom (Dockerfile.compliance_app) | 8002        | GET /docs    |
| frontend               | Custom (Dockerfile)                | 5173        | —            |
| redis                  | redis/redis-stack                  | 6379 / 8001 | —            |
| kafka                  | obsidiandynamics/kafka             | 9092        | —            |
| kafdrop                | obsidiandynamics/kafdrop           | 9000        | —            |

### Quick Start

```
# 1. Configure environment
cp backend/.env.sample backend/.env
# Edit backend/.env with your credentials (see Section 14)

cp frontend/.env.sample frontend/.env

# 2. Build and start all services
docker compose up --build -d

# 3. Check health
```

```
curl http://localhost:8000/health
# Expected: {"status":"healthy","service":"WealthVault"}

# 4. View API docs
open http://localhost:8000/docs
open http://localhost:8000/redoc

# 5. Kafka UI
open http://localhost:9000

# 6. Redis UI
open http://localhost:8001
```

## Database Seeding

The `backend_app` container automatically runs `python -m app.seed` on startup. This creates:

- Demo users (customer, employee, RM, admin, super\_admin roles)
- Sample accounts with balances
- Sample transactions, investments, loans
- KYC mock data
- Employee profiles for Sentinel

## Named Volumes

```
volumes:
  model_data:    # Shared ML model storage between backend_app and compliance_app
```

---

## 13. Development Timeline (Mar–Jun 2026)

### Phase 1: Genesis (Mar 6)

#### Week of Mar 6

- Mar 6 — Initial commit: project scaffolding, FastAPI skeleton, React Vite frontend initialized

---

### Phase 2: Foundation (Apr 14–18)

#### Week of Apr 14–18

- Apr 14 — Backend URL config, proxy setup for Vite dev server, CORS configuration, logifyx v1.0.4–v1.0.5 integration
- Apr 18 — SIPs page; email notifications (welcome + payment alerts); SMS OTP via Twilio; full initial backend setup; What-If financial scenario engine

---

### Phase 3: Security Hardening + Core Features (Apr 19–22)

#### Apr 19

- AES-256-GCM field-level encryption for all sensitive user and account fields
- Encrypted data handling in models and route handlers

#### Apr 20

- Cloudflare Turnstile CAPTCHA on register and login
- KYC approval flows for admin, employee, and relationship manager roles
- New device detection + IP geolocation lookup
- Behavior anomaly ML integration with email alert on suspicious login
- Fraud alert email template
- Risk scoring logic
- Three alert management endpoints (/notifications/alerts)
- Counting Bloom Filter implementation

#### Apr 21

- Password reset with OTP flow
- Recovery email and phone with OTP verification
- Session management with Redis (all active sessions per user)
- JWT session\_id claim for per-session revocation
- Account Aggregator (AA) framework for external bank linking
- Asset Vault with net worth computation
- Budget manager with per-category alerts
- Indian phone number validation (regex, Pydantic validator)
- Voice navigation + screen reader accessibility on hover
- Forgot password UI + backend flow
- Insider threat scan route for admin
- Behavioral anomaly detection with email alert on anomalous logins

#### Apr 22

- UPI QR code generation
- Tax optimization summary route
- Credit score computation route
- Compliance AI Assistant with Twilio voice integration and TwiML endpoints
- Redis caching decorator (cache\_response) + performance metrics endpoint (20-min Redis sorted set)
- Docker Compose multi-service setup with health checks and restart policies
- .dockerignore for both backend and frontend
- Kafka migration from kafka-python to aiokafka for async support
- Internationalization (i18n) with translation files (EN, HI, PA)
- Risk summary endpoint
- Unified notifications endpoint combining alerts and notifications
- SHA-256 index deduplication fix (drop-then-recreate unique indexes)
- Bank statement download in transactions
- Market news integration (Finnhub + NewsAPI)
- Glossary/PageInfoButton component for onboarding
- Data privacy centre page
- What-If calculator with AI-simulated scenarios
- Role-protected routes in frontend

- Notification bell in header
- 

## Phase 4: Polish + Reliability (Apr 23 – May 4)

### Apr 23–25

- Payment validation improvements and error handling
- Footer component
- UPI QR extension with payment mode detection
- PageLoader component across all pages
- Email delivery and first-time investor tips bug fixes

### Apr 28

- Migrated to `aioredis` for full async Redis (replaces sync client)
- OS-specific version detection in device service (Windows 10/11, macOS 11+)
- Kafka OTP verification event flow (email OTP now dispatched via Kafka)
- Navigation tutorial for new users + first-time investor popup

### May 2

- Auth cookie path fixed to `/` root (refresh endpoint was inaccessible)

### May 4

- Fire-and-forget email sending via `asyncio.create_task` (welcome, fraud alert, transaction alert)
  - Token retrieval priority: Authorization header first, `httpOnly` cookie fallback
- 

## Phase 5: AI & Compliance Expansion (May 23–25)

### May 23

- CycloneDX SBOM + CBOM generation integrated
- Additional security dependencies

### May 24

- Smart investment goal insights with NewsAPI integration
- Logout UX fix (clears Authorization header state)
- ML service behavior model retraining endpoint
- Biometric data handling in session service
- Security system + integration documentation in `/docs`

### May 25

- Credit score computation with 300–900 range and inertia algorithm (score evolves 35% toward target each compute)
  - Account creation/linking with account number and balance field updates
  - KYC OCR using Tesseract + OpenCV with Gaussian blur and Otsu thresholding
  - Google GenAI client integration as primary KYC extraction path
  - Verhoeff algorithm checksum validation on Aadhaar numbers
  - KYC status fallback logic for user profile edge cases
-

## Phase 6: Sentinel Simulation Lab (May 26–29)

### May 26

- Fraud simulation module added to project structure

### May 27

- Simulation email delivery system
- Campaign cancellation endpoint
- Module path reorganization (`sys.path` fixes)
- `dotenv` loading simplification
- Mock admin dashboard with simulation analytics
- Sentinel plugin additions (frontend + backend)

### May 28

- Fully functional Sentinel simulation setup for `super_admin` role
- Mail simulation updates and templates
- Phishing harvest + social engineering pages built
- `super_admin` role recognition in sidebar
- Persistent auth state implementation
- Sentinel plugin backend and frontend integration
- Simulation lab documentation (API references, subsystem overview, data models)

### May 29

- Enhanced simulation campaign logic (random targeting, bulk targeting)
- Dynamic notification handling in Reveal pages
- Employee debrief (Reveal) page and Learn page added
- Task pages with real-time behavioral tracking
- `InboxDetail` navigation improvements
- `AdminNotifications` component for real-time employee alerts
- Simulation seed execution changed to manual trigger
- `NotificationBell` and `AdminNotifications` refactored to static data fallback

---

## Phase 7: ML Integration + Firebase (Jun 1–4)

### Jun 1

- Navigation button UX: close reveal before redirect

### Jun 3

- New gRPC ML methods: `DetectSequenceAnomaly`, `DetectInsiderThreat`, `CalculateRiskScore`, `DetectBehaviorAnomaly`
- Architecture documentation update (`docs/architecture.md`)
- gRPC channel: auto-select secure vs insecure based on host scheme (`https://` vs `http://` vs plain `host:port`)
- `ML_GRPC_HOST` environment variable for dynamic ML server targeting
- HTTP fallback ML client (`m1_http.py`) for environments without gRPC
- HTTP ML router (`app/routes/m1_http.py`) with same interface as gRPC router

- Removed unused `m2_predict` endpoint
- Code readability refactoring pass

#### Jun 4

- Firebase FCM push notifications for large payment approvals (Flutter mobile app)
  - `firebase_service.py` With `_init_firebase()` and `send_payment_approval_notification()`
  - Mock frontend URLs in `.env` config (`MOCK_PORTAL_BASE_URL`, `SENTINEL_BASE_URL`)
  - Vite config update with EC2 in Docker host comments
  - Portal session phishing tracking URL updated to use mock frontend base URL
  - Email delivery functions updated to use `settings.FRONTEND_URL`
  - Code structure refactoring pass
- 

### Phase 8: Configuration Hardening (Jun 5–6)

#### Jun 5

- Firebase configuration moved to `.env.sample` with placeholder credentials
- `LARGE_PAYMENT_THRESHOLD` added to env config (■1,00,000 default)

#### Jun 6

- Draw.io integration for architecture diagrams
  - Custom flowchart skill added to `.claude/skills`
  - `docs/architecture.drawio` created
- 

### Phase 9: ML Auth + Persistence (Jun 11–17)

#### Jun 11

- logifys upgraded to v1.1.0
- Major code structure refactoring for readability and maintainability

#### Jun 17

- Bearer token authentication interceptor added to gRPC channel (`_BearerTokenInterceptor`, `_AuthCallDetails`)
  - `ML_API_TOKEN` config variable added for ML server authentication
  - HTTP ML client updated to use `Authorization: Bearer {ML_API_TOKEN}` header
  - `useUIStore` (frontend) refactored to include persistence and proper user preference initialization on login
- 

## 14. Environment Variables

---

```
# -- App -----
APP_NAME=WealthVault
APP_VERSION=1.0.0
DEBUG=true

# -- ML / gRPC -----
ML_GRPC_HOST=localhost:50051      # or https://ngrok-url for TLS tunnel
USING_GRPC=true                  # false -> use HTTP fallback
ML_HTTP_HOST=http://localhost:8009/api/v1
```

```

ML_API_TOKEN=<bearer-token>          # shared secret for ML server auth

# -- Mock Frontends (Sentinel) -----
MOCK_PORTAL_BASE_URL=http://localhost:5175
SENTINEL_BASE_URL=http://localhost:5174

# -- MongoDB -----
MONGODB_URL=mongodb://localhost:27017
MONGODB_DB_NAME=wealthvault

# -- Encryption -----
DATA_ENCRYPTION_KEY=<base64-encoded-32-byte-AES-key>  # AES-256-GCM
ENCRYPTION_KEY=<fernet-key>                          # Fernet for agents

# -- Email / Gmail -----
NO_REPLY_EMAIL=noreply@yourdomain.com
MAIL_PASSWORD=<gmail-app-password>
MAIL_SERVER=smtp.gmail.com
MAIL_PORT=587
MAIL_STARTTLS=true
MAIL_SSL_TLS=false
GMAIL_TOKEN_B64=<base64-encoded-gmail-oauth-token.pickle>

# -- Redis -----
REDIS_URL=redis://localhost:6379

# -- JWT -----
JWT_SECRET_KEY=<long-random-256bit-secret>
JWT_ALGORITHM=HS256
ACCESS_TOKEN_EXPIRE_MINUTES=30
REFRESH_TOKEN_EXPIRE_DAYS=7

# -- Groq (Compliance AI + Chatbot) -----
GROQ_API_KEY=<groq-api-key>
GROQ_MODEL=llama3-70b-8192

# -- RAG Configuration -----
EMBEDDING_MODEL=all-MiniLM-L6-v2
FAISS_INDEX_PATH=./data/faiss_index
CHUNK_SIZE=700
CHUNK_OVERLAP=100
TOP_K=5

# -- Voice Services -----
DEEPGRAM_API_KEY=<deepgram-key>
SARVAM_API_KEY=<sarvam-key>
STT_CONFIDENCE_THRESHOLD=0.65

# -- Rate Limiting -----
RATE_LIMIT_QUERY=30/minute
RATE_LIMIT_VOICE=10/minute

# -- Kafka -----
KAFKA_BOOTSTRAP_SERVERS=localhost:9092

# -- External Market APIs -----
MARKETSTACK_API_KEY=<key>
ALPHA_VANTAGE_API_KEY=<key>
FINNHUB_API_KEY=<key>
NEWS_API_KEY=<key>
EXCHANGERATE_API_KEY=<key>

# -- OTP -----
OTP_EXPIRE_SECONDS=300

```

```
# -- Firebase FCM -----
FIREBASE_CREDENTIALS_PATH=./walthvault-firebase-adminsdk-*.json
LARGE_PAYMENT_THRESHOLD=100000

# -- Twilio -----
ACCOUNT_SID=<twilio-account-sid>
AUTH_TOKEN=<twilio-auth-token>
TWILIO_PHONE_NUMBER=+1xxxxxxxxxx

# -- Cloudflare Turnstile -----
TURNSTILE_SECRET_KEY=<cloudflare-turnstile-secret>
ENABLE_TURNSTILE=true

# -- CORS / Frontend -----
FRONTEND_URL=http://localhost:5173,http://localhost:5174,http://localhost:3000
```

## 15. Project Structure

```
PSB/
+-- backend/
|   +-- app/
|   |   +-- app.py                # Main FastAPI app entry point
|   |   +-- compliance_app.py    # Compliance AI FastAPI app (port 8002)
|   |   +-- seed.py              # Database seeder (runs at startup)
|   |   |
|   |   +-- core/
|   |   |   +-- config.py         # Pydantic-settings configuration
|   |   |   +-- database.py       # MongoDB connection + index creation + backfill
|   |   |   +-- redis_client.py   # Redis client + cache_response decorator
|   |   |   +-- kafka_service.py  # Kafka producer/consumer + in-memory fallback
|   |   |   +-- bloom_filter.py   # Counting Bloom Filter (mmh3)
|   |   |   +-- security.py       # JWT, Argon2, get_current_user, require_role
|   |   |
|   |   +-- models/               # Pydantic request/response models
|   |   |   +-- user.py, account.py, investment.py, loan.py ...
|   |   |
|   |   +-- routes/               # FastAPI APIRouter files (20 routers)
|   |   |   +-- auth.py, accounts.py, transactions.py, payments.py
|   |   |   +-- investments.py, loans.py, ml.py, ml_http.py
|   |   |   +-- admin.py, kyc.py, notifications.py, sessions.py
|   |   |   +-- family.py, aa.py, assets.py, budgets.py
|   |   |   +-- credit.py, tax.py, risk.py, agents.py
|   |   |   +-- compliance.py, employee_notifications.py
|   |   |
|   |   +-- services/
|   |   |   +-- grpc_client.py    # gRPC ML client with Bearer token interceptor
|   |   |   +-- http_ml_client.py # HTTP ML client fallback
|   |   |   +-- kyc_service.py    # KYC OCR + Verhoeff + fraud detection
|   |   |   +-- credit_score_service.py # Credit score computation (300-900)
|   |   |   +-- firebase_service.py # FCM push notifications
|   |   |   +-- email_service.py  # Gmail / SMTP transactional emails
|   |   |   +-- sms_service.py    # Twilio SMS
|   |   |   +-- device_service.py # Device fingerprinting + geolocation
|   |   |   +-- turnstile_service.py # Cloudflare CAPTCHA verification
|   |   |   +-- deterministic_hash.py # SHA-256 PII hashing
|   |   |   +-- encryption.py     # AES-256-GCM field encryption
|   |   |   +-- event_consumers.py # Kafka event handler registrations
|   |   |   +-- aa_service.py     # Account Aggregator mock
|   |   |   +-- budget_service.py # Budget monitoring
|   |   |   +-- rag_client.py     # RAG pipeline HTTP client
```

```

| | | +-- compliance/          # Compliance AI components
| | |   +-- ingestion.py       # PDF loading + chunking
| | |   +-- embedding.py       # MiniLM-L6-v2 embeddings + FAISS
| | |   +-- retriever.py       # HybridRetriever (FAISS + BM25 + RRF)
| | |   +-- compliance_checker.py # Rule-based compliance classifier
| | |   +-- rag_pipeline.py     # Groq LLaMA-3 70B generation
| | |   +-- config.py          # Compliance-specific settings
| | |   +-- seed_data.py       # Regulatory document seeder
| | |
| | | +-- helper/
| | |   +-- audit_logger.py     # JSONL audit log with PII masking
| | |   +-- encryption_utils.py # Fernet encryption for agent payloads
| | |   +-- wealth_advisor_agent.py # Wealth Advisor LLM agent
| | |   +-- wealth_teacher_agent.py # Wealth Teacher LLM agent
| | |   +-- verhoeff.py         # Aadhaar checksum algorithm
| | |   +-- helpers.py          # Query normalization, voice truncation
| | |   +-- language_detection.py # EN/HI/PA language detection
| | |   +-- utils.py            # AES decrypt utility, data helpers
| | |
| | | +-- simulation/          # Sentinel Simulation Lab
| | |   +-- routes/
| | |     +-- admin.py         # SuperAdmin campaign management
| | |     +-- portal.py        # Employee mock portal (honeypot)
| | |     +-- sim_tracking.py   # Real-time behavior tracking
| | |   +-- services/
| | |     +-- campaign_service.py # Email delivery + attempt tracking
| | |     +-- scoring.py         # Pass/fail + risk score computation
| | |     +-- scraper.py         # OSINT employee exposure scraper
| | |     +-- report_generator.py # Security posture reports
| | |     +-- email_service.py   # Simulation email delivery
| | |     +-- token_service.py   # Simulation token generation
| | |   +-- models/
| | |     +-- simulation.py      # Pydantic models for campaigns/attempts
| | |   +-- seed.py             # Employee profile seeder
| | |
| | | +-- shared/proto/
| | |   +-- ml.proto            # gRPC service + message definitions
| | |   +-- ml_pb2.py          # Generated protobuf classes
| | |   +-- ml_pb2_grpc.py     # Generated gRPC stubs
| | |
| | | +-- data/
| | |   +-- faiss_index         # FAISS vector store (persisted)
| | | +-- logs/
| | |   +-- audit.jsonl         # Compliance AI audit log (PII-masked)
| | |   +-- wealthvault.log     # Rotating app log
| | | +-- Dockerfile.app        # Main app container
| | | +-- Dockerfile.compliance_app # Compliance AI container
| | | +-- pyproject.toml        # Dependencies (uv/pip)
| | |
| | | +-- frontend/
| | |   +-- src/
| | |     +-- App.tsx          # Root + router
| | |     +-- api.ts           # Typed API client (axios)
| | |     +-- components/      # Shared UI components
| | |     +-- pages/           # Route-level page components
| | |     +-- hooks/           # Custom React hooks
| | |
| | | +-- docker-compose.yml    # Full stack orchestration
| | | +-- docs/
| | |   +-- architecture.md     # Architecture deep-dive
| | |   +-- architecture.drawio # Draw.io architecture diagram
| | |   +-- api_documentation.md # Full API reference
| | |   +-- security_system.md   # Security system documentation
| | |   +-- deployment_guide.md  # Deployment instructions
| | |   +-- features.md          # Feature specifications

```

---

*WealthVault — Built with security, scale, and simplicity in mind for PSB Hackathon 2026.*

*Team: WealthVault*